

PERTEMUAN KE-9 ^{2TM}

Manajemen Risiko Keamanan Informasi



Ahmad Fahrudi Setiawan

Dr. med., S.Kom., MT., MH. 

You should have known this—

a quiet truth waiting in the space between words.....



Ahmad Fahrudi Setiawan

Dr. med., S.Kom., MT., MH.

MATAKULIAH

KEAMANAN INFORMASI

**S1 TEKNIK INFORMATIKA
ITN MALANG**



Dr. Rudi Setiawan S.Kom., MT,. MH

DOSEN SARJANA DAN PASCA SARJANA FTI ITN MALANG

Manajemen Risiko Keamanan Informasi

Risk **management** is not about avoiding every possible threat, but **about building** resilience and ensuring we are fully prepared when risks **inevitably** arise.

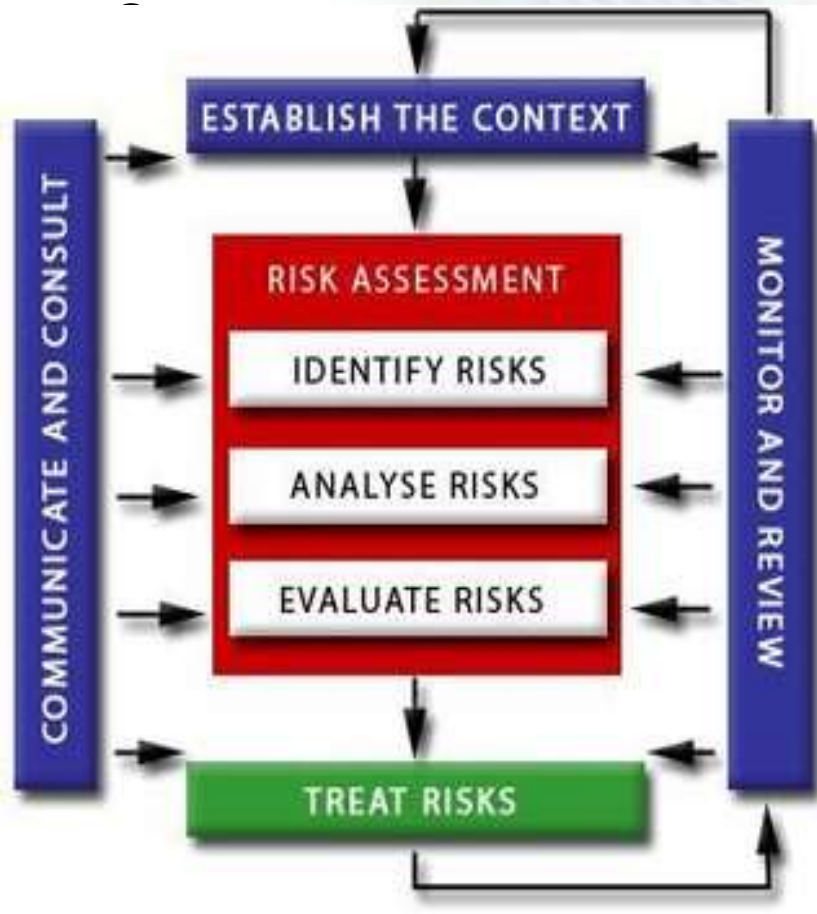
Manajemen risiko bukan tentang menghindari setiap ancaman yang **mungkin terjadi**, tetapi tentang membangun ketahanan dan memastikan kita benar-benar **siap** ketika risiko tidak dapat **dihindari** muncul.



Dr. Rudi Setiawan S.Kom MT. MH.

DOSEN SARJANA & PASCA FTI ITN MALANG

Manajemen Risiko Keamanan



1. Pengantar Manajemen Risiko Keamanan Informasi
2. Identifikasi Risiko Keamanan Informasi
3. Analisis dan Evaluasi Risiko
4. Mitigasi dan Pengendalian Risiko

5. Pemantauan dan Review Risiko

6. Kepatuhan dan Regulasi

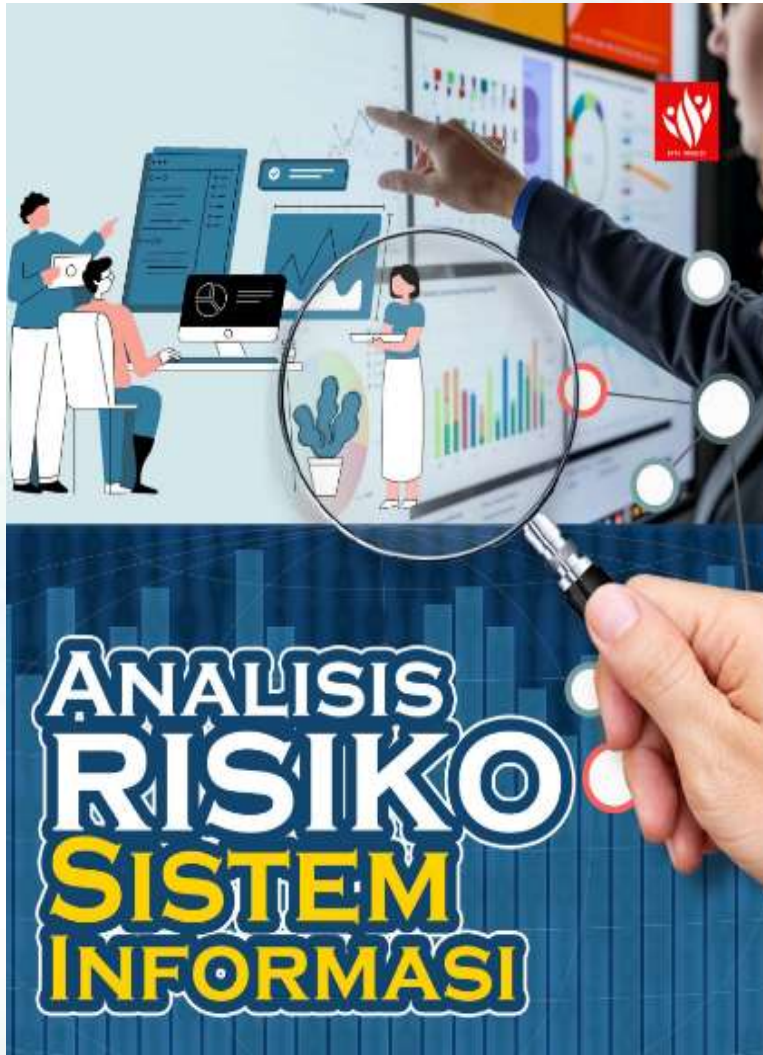
1. Pengantar Manajemen Risiko Keamanan Informasi



- a. Definisi Manajemen Risiko Keamanan Informasi
- b. Tujuan dan Pentingnya Manajemen Risiko
- c. Kerangka Kerja Manajemen Risiko

2. Identifikasi Risiko Keamanan Informasi

- a. Jenis Ancaman Keamanan Informasi (Malware, Phishing, Insider Threats, dll.)
- b. Kerentanan dalam Sistem Informasi
- c. Sumber Risiko (Internal dan Eksternal)



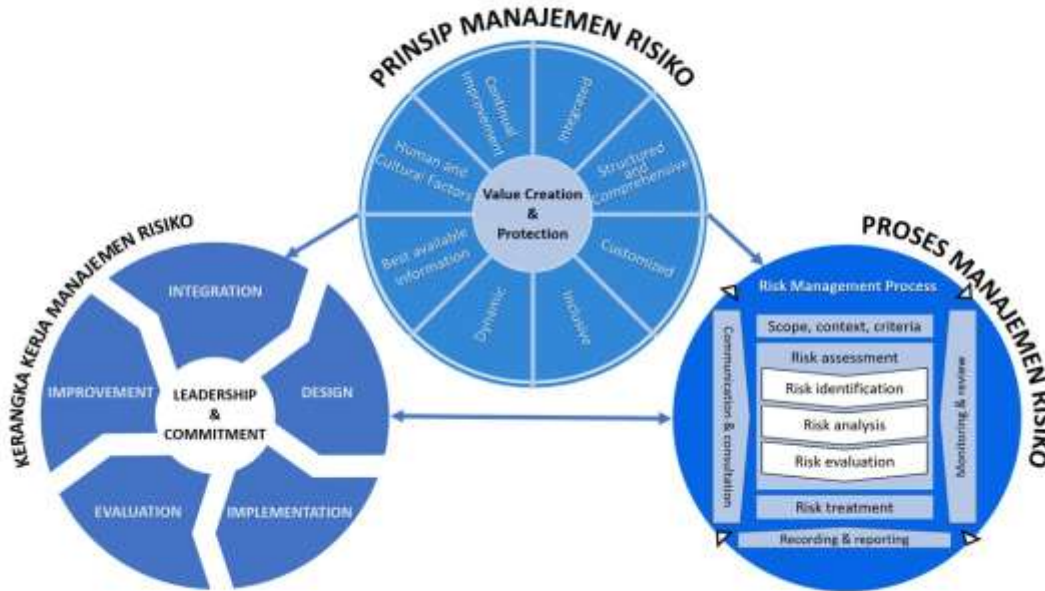
3. Analisis dan Evaluasi Risiko

- a. Metode Analisis Risiko (Kualitatif vs. Kuantitatif)
- b. Matriks Risiko (Likelihood & Impact)
- c. Penentuan Prioritas Risiko

RISK ASSESSMENT MATRIX						
LIKELIHOOD	Hampir Pasti	5	10	15	20	25
	Kemungkinan Besar	4	8	12	16	20
	Kemungkinan Sedang	3	6	9	12	15
	Kemungkinan Kecil	2	4	6	8	10
	Jarang	1	2	3	4	5
		Sangat Rendah	Rendah	Sedang	Tinggi	Sangat Tinggi
IMPACT						

4. Mitigasi dan Pengendalian Risiko

- Strategi Penanganan Risiko (Menghindari, Mengurangi, Menerima, atau Mentransfer)
- Implementasi Kontrol Keamanan (Teknis, Administratif, dan Fisik)
- Framework Keamanan Informasi (ISO 27001, NIST, COBIT, dll.)



5. Pemantauan dan Review Risiko

- Audit dan Penilaian Risiko Secara Berkala
- Incident Response dan Penanganan Insiden
- Continuous Improvement dalam Manajemen Risiko



**Peran Audit
Kepatuhan
Keamanan Informasi
dalam Melindungi
Data Perusahaan**



6. Kepatuhan dan Regulasi

- a. Regulasi dan Standar Keamanan Informasi (GDPR, UU ITE, dll.)
- b. Kebijakan dan Prosedur Keamanan Informasi dalam Organisasi



LET'S START

1. Pengantar Manajemen Risiko Keamanan Informasi

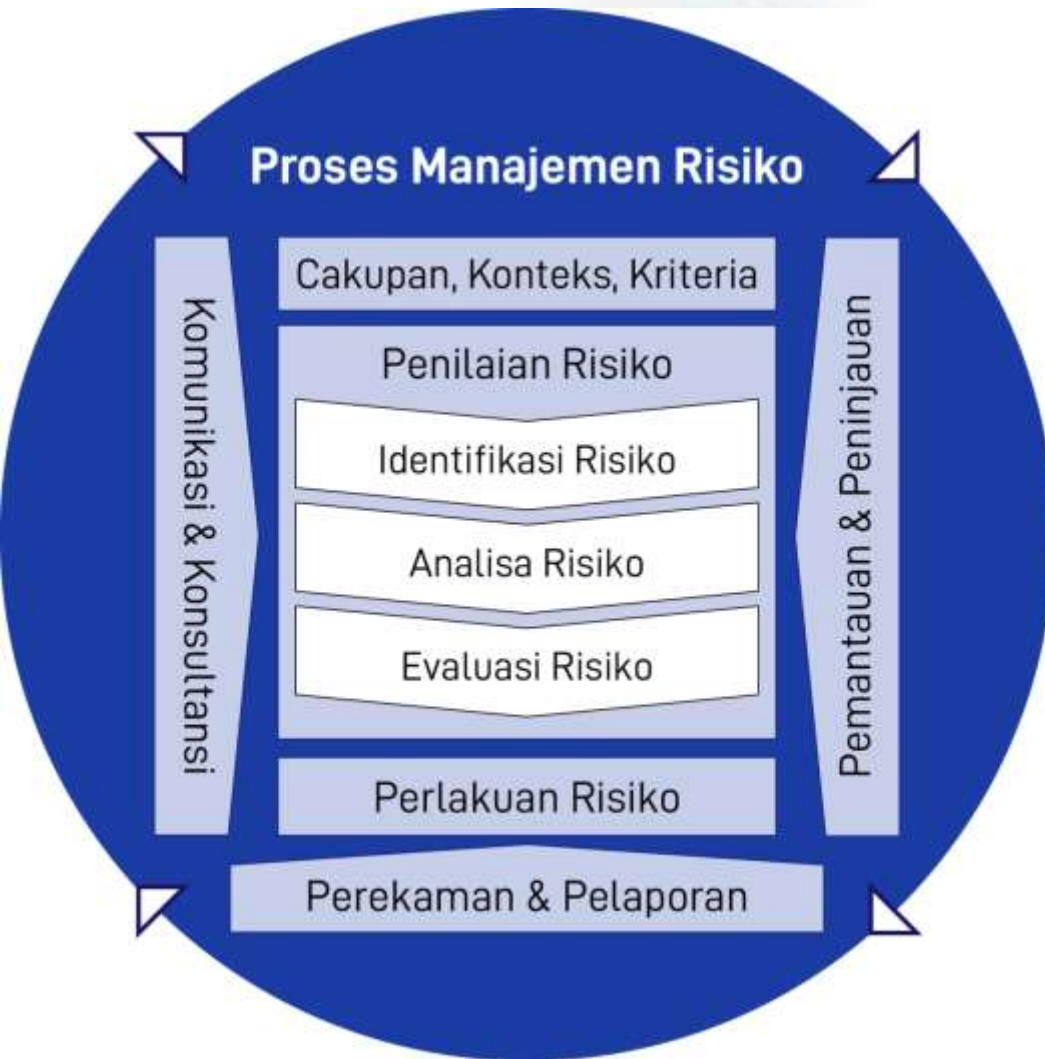
Definisi Manajemen Risiko Keamanan Informasi

Manajemen risiko keamanan informasi adalah proses sistematis dalam mengidentifikasi, menilai, dan mengurangi risiko yang dapat mengancam kerahasiaan, integritas, dan ketersediaan informasi dalam suatu organisasi.



Tujuan dan Pentingnya Manajemen Risiko

- a. **Melindungi data** dari ancaman eksternal maupun internal.
- b. **Mencegah kebocoran informasi** yang dapat merugikan organisasi.
- c. **Memastikan kelangsungan bisnis** dengan mengurangi potensi gangguan akibat insiden keamanan.
- d. **Meningkatkan kepatuhan** terhadap regulasi dan standar keamanan.



Kerangka Kerja Manajemen Risiko

Kerangka kerja yang sering digunakan:

- ISO 27005** (Standar Manajemen Risiko Keamanan Informasi)
- NIST Risk Management Framework (RMF)**
- COBIT (Control Objectives for Information and Related Technologies)**

2. Identifikasi Risiko Keamanan Informasi

Jenis Ancaman Keamanan Informasi

- **Serangan siber** (Malware, Phishing, Ransomware, DDoS)
- **Kesalahan manusia** (Human error, Social Engineering)
- **Insider Threats** (Pegawai yang berniat jahat atau ceroboh)
- **Bencana alam** (Gempa, banjir, kebakaran)



Kerentanan dalam Sistem Informasi

- Kelemahan perangkat lunak (Bug, Patch yang belum diinstal)
- Kurangnya kebijakan keamanan
- Kurangnya kesadaran pengguna terhadap keamanan



Sumber Risiko

- **Internal:** Kesalahan pengguna, karyawan yang tidak puas, sistem yang rentan.
- **Eksternal:** Hacker, kompetitor, vendor pihak ketiga, dan bencana alam.



3. Analisis dan Evaluasi Risiko

Metode Analisis Risiko

- **Kualitatif:** Menilai risiko berdasarkan kategori tingkat dampak (Tinggi, Sedang, Rendah).
- **Kuantitatif:** Menghitung risiko berdasarkan nilai keuangan atau numerik.

Matriks Risiko (Likelihood & Impact)

Digunakan untuk menentukan tingkat risiko berdasarkan:

- **Kemungkinan (Likelihood):** Seberapa sering ancaman terjadi.
- **Dampak (Impact):** Seberapa besar kerugian yang dapat ditimbulkan

Likelihood	Impact Rendah	Impact Sedang	Impact Tinggi
Rendah	Risiko Kecil	Risiko Sedang	Risiko Tinggi
Sedang	Risiko Sedang	Risiko Tinggi	Risiko Sangat Tinggi
Tinggi	Risiko Tinggi	Risiko Sangat Tinggi	Risiko Kritis

Penentuan Prioritas Risiko

Risiko dengan dampak tinggi dan kemungkinan tinggi harus ditangani terlebih dahulu.

4. Mitigasi dan Pengendalian Risiko



Strategi Penanganan Risiko

- **Menghindari Risiko (Risk Avoidance):** Menghapus atau tidak menjalankan proses yang berisiko.
- **Mengurangi Risiko (Risk Reduction):** Menerapkan langkah-langkah pencegahan seperti enkripsi atau firewall.
- **Menerima Risiko (Risk Acceptance):** Menerima risiko jika dampaknya kecil dan tidak ada solusi yang layak.
- **Mentransfer Risiko (Risk Transfer):** Mengalihkan risiko ke pihak lain, misalnya dengan asuransi.

Implementasi Kontrol Keamanan

- **Kontrol Teknis:** Firewall, Antivirus, Multi-Factor Authentication (MFA).
- **Kontrol Administratif:** Kebijakan keamanan, pelatihan karyawan, manajemen akses.
- **Kontrol Fisik:** CCTV, keamanan gedung, akses terbatas ke ruang server.

Framework Keamanan Informasi

- **ISO 27001:** Standar internasional untuk Sistem Manajemen Keamanan Informasi (ISMS).
- **NIST Cybersecurity Framework:** Panduan praktik terbaik untuk mengelola risiko keamanan siber.



5. Pemantauan dan Review Risiko



Audit dan Penilaian Risiko Secara Berkala

- Melakukan **Penetration Testing (Pentest)** untuk menguji keamanan sistem.
- Menggunakan **Security Information and Event Management (SIEM)** untuk memonitor log keamanan.

7 PHASES OF INCIDENT RESPONSE

1

Preparing for Potential Incidents

Define clear communication channels, implement response checklists, and provide staff with quality cybersecurity training.



2

Identifying and Assessing Threats

Assess whether an event is a cyber-attack, evaluate its intensity, and classify the cybersecurity incident based on the nature of the attack.



3

Containing the Impact

Isolate the affected systems and impede the incident from propagating further.



4

Investigating and Eradicating Threats

Make sure the threat is no longer present in the organization's network by investigating the root cause of the incident and eradicating any threats from the system.



5

Recovering and Restoring Operations

Restore the affected systems to their pre-incident state to get your business back up and running as normal.



6

Learning from the Incident

Document everything that occurred during the incident and the response. Use this information to recognize areas for improvement in the organization's security posture and incident response plan.



7

Ongoing Testing and Evaluation

Strengthen your security posture by continuously testing and evaluating your incident response plan to ensure that it remains current and effective in the face of ever-evolving cyber threats.



Incident Response dan Penanganan Insiden

- **Identifikasi:** Mengidentifikasi insiden yang terjadi.
- **Tanggap Darurat:** Mengisolasi sistem yang terkena dampak.
- **Analisis Forensik:** Menyelidiki penyebab insiden.
- **Pemulihan (Recovery):** Memulihkan sistem yang terdampak.
- **Evaluasi dan Perbaikan:** Menganalisis kejadian untuk mencegah insiden serupa di masa depan.

Continuous Improvement dalam Manajemen Risiko

- Melakukan pembaruan kebijakan berdasarkan tren ancaman terbaru.
- Mengikuti perkembangan teknologi keamanan informasi



**Peran Audit
Kepatuhan
Keamanan Informasi
dalam Melindungi
Data Perusahaan**



Kepatuhan dan Regulasi

Regulasi dan Standar Keamanan Informasi

6. Kepatuhan dan Regulasi



Regulasi dan Standar Keamanan Informasi

- **GDPR (General Data Protection Regulation)** – Regulasi perlindungan data di Eropa.
- **UU ITE (Undang-Undang Informasi dan Transaksi Elektronik)** – Regulasi keamanan siber di Indonesia.
- **PCI DSS (Payment Card Industry Data Security Standard)** – Standar keamanan untuk transaksi kartu kredit.

Kebijakan dan Prosedur Keamanan Informasi dalam Organisasi

- Menyusun **Information Security Policy** untuk mengatur perlindungan data.
- Memberikan **pelatihan keamanan** bagi karyawan.
- Menerapkan **access control** untuk membatasi hak akses berdasarkan peran.



1. ISO 27005 (Standar Manajemen Risiko Keamanan Informasi)

ISO/IEC 27005 adalah standar internasional yang dirancang untuk membantu organisasi dalam **mengelola risiko keamanan informasi** sebagai bagian dari Sistem Manajemen Keamanan Informasi (ISMS) yang sesuai dengan **ISO/IEC 27001**.

Isi Utama ISO 27005:

- **Pendahuluan tentang manajemen risiko** dalam keamanan informasi.
- **Identifikasi aset informasi, ancaman, dan kerentanan** dalam organisasi.
- **Analisis risiko**, termasuk penilaian kemungkinan dan dampaknya.
- **Evaluasi dan prioritas risiko** menggunakan metode kualitatif atau kuantitatif.
- **Strategi mitigasi dan pengendalian risiko**, seperti enkripsi, firewall, atau pelatihan keamanan.
- **Pemantauan dan tinjauan berkelanjutan** untuk memastikan efektivitas kontrol keamanan.

👉 **Keunggulan:** Standar ini memberikan kerangka kerja yang fleksibel dan dapat disesuaikan dengan berbagai jenis organisasi.

2. NIST Risk Management Framework (RMF)



NIST RMF adalah pendekatan berbasis risiko yang dikembangkan oleh **National Institute of Standards and Technology (NIST)** di AS untuk membantu organisasi mengelola keamanan sistem informasi dan kepatuhan terhadap standar keamanan siber.

Tahapan dalam NIST RMF:

- **Categorize (Kategorisasi Sistem)**
 - Menentukan tingkat sensitivitas dan dampak sistem terhadap organisasi.
- **Select (Memilih Kontrol Keamanan)**
 - Menggunakan NIST 800-53 sebagai panduan dalam memilih kontrol keamanan yang sesuai.
- **Implement (Implementasi Kontrol)**
 - Menerapkan langkah-langkah keamanan yang telah dipilih.
- **Assess (Penilaian Keamanan)**
 - Menguji dan mengevaluasi efektivitas kontrol yang diterapkan.
- **Authorize (Otorisasi Sistem)**
 - Memutuskan apakah sistem dapat digunakan berdasarkan hasil evaluasi.
- **Monitor (Pemantauan Berkelanjutan)**
 - Mengawasi sistem secara berkala dan memperbarui kontrol keamanan sesuai ancaman baru.

👉 **Keunggulan:** NIST RMF banyak digunakan oleh lembaga pemerintah AS dan organisasi yang memerlukan kepatuhan ketat terhadap standar keamanan.

3. COBIT (Control Objectives for Information and Related Technologies)



COBIT adalah kerangka kerja yang dikembangkan oleh **ISACA** untuk membantu organisasi dalam **mengelola dan mengendalikan teknologi informasi (TI)** agar sejalan dengan tujuan bisnis.

Struktur COBIT 2019 (Versi Terbaru)

COBIT terdiri dari 6 prinsip utama:

- **Memenuhi kebutuhan pemangku kepentingan**
- **Mencakup keseluruhan organisasi**
- **Menerapkan pendekatan holistik**
- **Menentukan tanggung jawab tata kelola yang jelas**
- **Menerapkan sistem manajemen kinerja**
- **Mengintegrasikan tata kelola TI dengan tata kelola perusahaan**

Komponen COBIT:



- **Framework Tata Kelola TI:** Memberikan panduan bagaimana mengelola risiko TI.
- **Proses-proses Manajemen TI:** Terdiri dari 40+ proses, seperti **APO12 (Manage Risk)** yang khusus untuk manajemen risiko TI.
- **Model Maturity Level:** Mengukur seberapa matang implementasi TI dalam organisasi.

👉 **Keunggulan:** COBIT sangat cocok untuk perusahaan yang ingin meningkatkan tata kelola TI dan memastikan TI mendukung strategi bisnis.



Kesimpulan & Perbandingan

Framework/Standar	Fokus Utama	Digunakan Oleh	Metode
ISO 27005	Manajemen risiko keamanan informasi	Semua organisasi	Berbasis risiko
NIST RMF	Pengelolaan keamanan sistem informasi	Pemerintah AS, Perusahaan dengan regulasi ketat	Berbasis siklus hidup sistem
COBIT	Tata kelola dan manajemen TI	Perusahaan yang ingin meningkatkan tata kelola TI	Framework bisnis & IT

Jangan lupa presensi dulu



**SIDOSEN ITN**

Sistem Informasi Akademik Mahasiswa
Institut Teknologi Nasional Malang

AKSES NILAI MAHASISWA DAN ABSENSI LEBIH MUDAH

Our services:

- Nilai
- Presensi
- Informasi
- Keuangan



Contact Us : 088026124924

 1178



Sign In

Dev. by SIM-ITN Malang, Copyright. 2018

PRESENSI PERKULIAHAN KELAS (2025 GENAP)

Mata Kuliah

FISIKA - KEAMANAN INFORMASI

Kelas

Kelas A

Portemon

1

Materi

Manajemen Risiko Keamanan Informasi

Tanggal

28 April 2025

Jam Mulai

10:33 AM

Jam Berakhir

10:33 AM

Ruang Kelas

RL3.2

Keterangan

Pengisian Kelas

Dikun Terpenuhi

Kirim



**Peran Audit
Kepatuhan
Keamanan Informasi
dalam Melindungi
Data Perusahaan**



**Kepatuhan dan Regulasi
Kebijakan dan Prosedur Keamanan
Informasi dalam Organisasi**

1. Contoh Implementasi ISO 27005

Kasus: Sebuah perusahaan e-commerce ingin mengidentifikasi dan mengelola risiko keamanan informasi dalam sistem pembayaran online mereka.

Langkah Implementasi ISO 27005:

1. Identifikasi Aset

1. Aset utama: **Data pelanggan (informasi kartu kredit, alamat, email, dll.)**
2. Sistem yang terlibat: **Server database, sistem pembayaran, jaringan perusahaan**

2. Identifikasi Ancaman & Kerentanan

1. **Ancaman:** Serangan malware, pencurian data, serangan DDoS.
2. **Kerentanan:** Penggunaan kata sandi lemah, patch keamanan tidak diperbarui, kurangnya enkripsi data.

3. Analisis Risiko

1. Kemungkinan serangan: Tinggi
2. Dampak jika terjadi: Sangat tinggi (potensi kehilangan data pelanggan, denda regulasi, reputasi buruk)
3. **Hasil:** Risiko dikategorikan sebagai "KRITIS"

4. Mitigasi Risiko

1. Menerapkan **Multi-Factor Authentication (MFA)** untuk akses pengguna.
2. Menggunakan **enkripsi SSL/TLS** pada semua transaksi.
3. Menerapkan **patching otomatis** untuk sistem yang rentan.

5. Pemantauan & Review

1. Melakukan **audit keamanan berkala**.
2. Mengadakan **pelatihan keamanan** bagi karyawan.

2. Contoh Implementasi NIST RMF

Kasus: Sebuah lembaga pemerintah perlu mengamankan sistem informasi yang menangani data sensitif warga negara.

Langkah Implementasi NIST RMF:

1. Categorize (Kategorisasi Sistem)

1. Data yang diproses: **Data pribadi warga negara**
2. Klasifikasi: **Sangat Sensitif (Highly Confidential)**

2. Select (Memilih Kontrol Keamanan)

1. Menggunakan **NIST 800-53** untuk memilih kontrol keamanan.
2. Contoh kontrol yang diterapkan:
 1. **AC-2** (Manajemen Akses) → Hanya pengguna berwenang yang bisa mengakses sistem.
 2. **SC-12** (Enkripsi Data) → Semua data dienkripsi menggunakan AES-256.

3. Implement (Implementasi Kontrol)

1. Menggunakan **firewall tingkat tinggi** untuk membatasi akses tidak sah.
2. Memasang **sistem deteksi intrusi (IDS)** untuk memantau aktivitas mencurigakan.

4. Assess (Penilaian Keamanan)

1. Melakukan **penetration testing (pentest)** setiap enam bulan.
2. Melakukan audit keamanan menggunakan tools seperti **Nessus** atau **Qualys**.

5. Authorize (Otorisasi Sistem)

1. Otorisasi diberikan setelah sistem lolos audit keamanan dan memenuhi persyaratan NIST RMF.

6. Monitor (Pemantauan Berkelanjutan)

1. Menggunakan **SIEM (Security Information and Event Management)** untuk memantau ancaman secara real-time.
2. Melakukan **pembaruan reguler** terhadap kebijakan keamanan berdasarkan insiden yang terjadi.

3. Contoh Implementasi COBIT

Kasus: Sebuah perusahaan perbankan ingin meningkatkan tata kelola TI dan memastikan sistem mereka memenuhi standar kepatuhan perbankan.

Langkah Implementasi COBIT:

1. Menentukan Tujuan Tata Kelola TI

1. Tujuan utama: **Meningkatkan keamanan transaksi online & kepatuhan regulasi**

2. Menerapkan Proses COBIT yang Relevan

1. **APO12 (Manage Risk)** → Menganalisis dan mengelola risiko terkait TI.
2. **BAI06 (Manage Changes)** → Memastikan setiap perubahan dalam sistem TI tidak menimbulkan risiko keamanan.
3. **DSS05 (Manage Security Services)** → Mengelola keamanan TI untuk melindungi data pelanggan.

3. Pengukuran dan Evaluasi Kinerja

1. Menggunakan **Key Performance Indicators (KPI)**, misalnya:
 1. **Waktu rata-rata pemulihan dari serangan siber (MTTR - Mean Time to Recover).**
 2. **Jumlah insiden keamanan per bulan.**

4. Penerapan Kontrol Keamanan TI

1. Menetapkan **struktur tanggung jawab keamanan** dalam organisasi.
2. Menggunakan **framework ISO 27001** sebagai acuan dalam pengamanan data.

5. Evaluasi dan Peningkatan Berkelanjutan

1. Melakukan **audit TI tahunan** berdasarkan standar COBIT.
2. Menyesuaikan kebijakan TI dengan perubahan regulasi pemerintah.

1. GDPR (General Data Protection Regulation)

GDPR adalah regulasi perlindungan data yang berlaku di Uni Eropa (UE) dan European Economic Area (EEA), yang mulai diberlakukan pada **25 Mei 2018**. Regulasi ini bertujuan untuk **melindungi privasi dan data pribadi warga Uni Eropa** serta memberikan kontrol lebih besar kepada individu atas data mereka.

Isi Utama GDPR:

Prinsip Perlindungan Data (Article 5)

- **Lawfulness, fairness, and transparency** → Pengolahan data harus sah, adil, dan transparan.
- **Purpose limitation** → Data hanya boleh digunakan untuk tujuan yang spesifik dan sah.
- **Data minimization** → Hanya data yang diperlukan yang boleh dikumpulkan.
- **Accuracy** → Data harus akurat dan diperbarui secara berkala.
- **Storage limitation** → Data tidak boleh disimpan lebih lama dari yang diperlukan.
- **Integrity and confidentiality** → Data harus dilindungi dari akses tidak sah dan kebocoran.

Hak Subjek Data (Article 12-23)

- **Right to access** → Pengguna berhak mengetahui data apa yang dikumpulkan tentang mereka.
- **Right to be forgotten (Right to erasure)** → Pengguna bisa meminta penghapusan data mereka.
- **Right to data portability** → Pengguna bisa meminta data mereka dalam format yang dapat dipindahkan ke sistem lain.
- **Right to object** → Pengguna bisa menolak pemrosesan data mereka untuk tujuan tertentu.

Kewajiban Pengendali dan Pemroses Data

- Harus mendapatkan izin eksplisit sebelum mengumpulkan data.
- Harus melaporkan pelanggaran data dalam waktu 72 jam.
- Wajib menunjuk Data Protection Officer (DPO) jika memproses data dalam skala besar.

Sanksi dan Denda

- Pelanggaran GDPR dapat dikenakan denda hingga **€20 juta atau 4% dari omzet tahunan global**, mana yang lebih besar.

👉 Contoh Implementasi:

- Perusahaan teknologi seperti Google, Facebook, dan Amazon harus mengubah kebijakan privasi mereka agar sesuai dengan GDPR.
- Website yang menargetkan pengguna di Uni Eropa harus menyediakan opsi **cookie consent** yang transparan.

2. UU ITE (Undang-Undang Informasi dan Transaksi Elektronik) – Indonesia UU ITE (Undang-Undang Nomor 11 Tahun 2008) adalah regulasi utama di Indonesia yang mengatur **keamanan siber, transaksi elektronik, dan perlindungan data pribadi**. UU ini telah diperbarui melalui **UU No. 19 Tahun 2016**.

Isi Utama UU ITE:

Tindakan yang Dilarang

- **Pencemaran nama baik & fitnah online (Pasal 27 Ayat 3)**
- **Penyebaran berita bohong (hoaks) yang menyesatkan (Pasal 28 Ayat 1)**
- **Penyebaran konten pornografi dan perjudian (Pasal 27 Ayat 1 & 2)**
- **Akses ilegal ke sistem komputer atau hacking (Pasal 30)**
- **Pencurian data pribadi dan penyadapan ilegal (Pasal 31)**

Keamanan Transaksi Elektronik

- Dokumen elektronik dianggap **sah sebagai alat bukti hukum** (Pasal 5 & 6).
- Tanda tangan digital dan enkripsi harus digunakan untuk melindungi transaksi elektronik.

Perlindungan Data Pribadi (Sebagai Bagian dari UU PDP yang Diharmonisasi)

- Data pribadi yang dikumpulkan harus mendapatkan **persetujuan eksplisit dari pemiliknya**.
- Penyalahgunaan data pribadi dapat dikenakan sanksi pidana.

Sanksi dan Hukuman

- **Denda hingga Rp12 miliar dan hukuman penjara hingga 12 tahun** tergantung pada jenis pelanggaran.

👉 Contoh Implementasi:

- Kasus pencemaran nama baik melalui media sosial dapat dikenakan sanksi berdasarkan Pasal 27.
- Perusahaan yang menangani transaksi digital harus menerapkan **sistem keamanan yang sesuai dengan standar enkripsi**.

3. PCI DSS (Payment Card Industry Data Security Standard)

PCI DSS adalah standar keamanan global yang dibuat oleh **PCI Security Standards Council (PCI SSC)** untuk memastikan transaksi kartu kredit dan debit aman dari pencurian data.

Isi Utama PCI DSS:

PCI DSS memiliki 12 persyaratan utama yang dikelompokkan dalam 6 kategori:

- **Membangun dan Memelihara Jaringan yang Aman**
 - Pasang **firewall** untuk melindungi data pemegang kartu.
 - Tidak menggunakan **password default** dari vendor.
- **Melindungi Data Pemegang Kartu**
 - **Enkripsi data kartu kredit** selama penyimpanan dan pengiriman.
 - Gunakan **Tokenization atau Masking** untuk menyembunyikan nomor kartu asli.
- **Menjaga Program Manajemen Kerentanan**
 - Memperbarui software keamanan dan menerapkan **patch keamanan** secara berkala.
 - Gunakan **antivirus yang diperbarui**.

- **Menerapkan Tindakan Kontrol Akses yang Kuat**
 - Batasi akses ke data berdasarkan "**need to know basis**".
 - Gunakan **Multi-Factor Authentication (MFA)** untuk akses sistem sensitif.
- **Memantau dan Menguji Jaringan Secara Berkala**
 - Gunakan **sistem deteksi dan pencegahan intrusi (IDS/IPS)**.
 - Lakukan **penetration testing** secara berkala untuk mencari celah keamanan.
- **Menjaga Kebijakan Keamanan Informasi**
 - Menerapkan pelatihan keamanan untuk pegawai yang menangani data kartu kredit.
 - Dokumentasikan kebijakan dan prosedur keamanan.

Tingkatan Kepatuhan PCI DSS

- **Level 1:** Perusahaan yang memproses lebih dari **6 juta transaksi kartu per tahun** (misalnya, Amazon, Apple, Visa).
- **Level 2-4:** Perusahaan yang memproses lebih sedikit transaksi harus tetap memenuhi persyaratan keamanan, tetapi tidak selalu diwajibkan melakukan audit ketat.

Sanksi bagi Perusahaan yang Tidak Mematuhi PCI DSS

- **Denda dari \$5.000 hingga \$100.000 per bulan.**
- **Pemutusan izin untuk memproses pembayaran kartu kredit** oleh perusahaan seperti Visa dan Mastercard.

☞ Contoh Implementasi:

- Bank dan e-commerce harus memastikan bahwa **data kartu pelanggan tidak disimpan tanpa enkripsi.**
- Payment Gateway seperti **PayPal dan Stripe** harus mematuhi PCI DSS agar bisa terus memproses pembayaran kartu.



Kesimpulan & Perbandingan

Regulasi/Standar	Fokus Utama	Diterapkan Oleh	Konsekuensi Pelanggaran
GDPR	Perlindungan data pribadi warga UE	Semua organisasi yang menangani data UE	Denda hingga €20 juta atau 4% dari pendapatan tahunan
UU ITE	Keamanan siber dan transaksi elektronik di Indonesia	Semua pengguna dan perusahaan di Indonesia	Hukuman penjara hingga 12 tahun atau denda hingga Rp12 miliar
PCI DSS	Keamanan transaksi kartu kredit	Bank, e-commerce, payment gateway	Denda hingga \$100.000/bulan atau pemutusan layanan kartu kredit

Quote hari ini...



In the digital world, data is one of the most **valuable assets an organization** owns—and effective risk management serves as the guardian that protects its integrity, **confidentiality**, and availability.

Di dunia digital, data adalah salah satu aset paling **berharga yang dimiliki** organisasi—dan manajemen risiko yang efektif berperan sebagai penjaga yang melindungi integritas, kerahasiaan, dan ketersediaannya.

Dr. Ken Rudy S.Kom MT. MH.

DOSEN & POLITISI KOTA MALANG

Kepak Elang...



1996

Ahmad Fahrudi Setiawan

Dr. med., S.Kom., MT., MH.